

個人情報保護規程

第2版 2026年4月1日 発行

株式会社ブリックスマート 法務部 / 情報セキュリティ委員会

第1章 目的と適用範囲

1.1 目的

本規程は、株式会社ブリックスマート（以下「当社」）が取り扱う個人情報の適切な保護と管理を目的とする。個人情報の保護に関する法律（個人情報保護法）および関連法規に準拠する。

1.2 適用範囲

- ・当社の全役員・従業員（正社員、契約社員、アルバイト、派遣社員を含む）
- ・当社の業務委託先（個人情報を取り扱う場合）
- ・当社が運営するECサイト「ブリックスマート」で取得する全ての個人情報

第2章 個人情報の定義

2.1 取り扱う個人情報の種類

区分	具体例	取得経路
会員情報	氏名、メールアドレス、パスワード（ハッシュ化）、電話番号	会員登録時
配送情報	住所、氏名、電話番号	注文時
決済情報	クレジットカード番号（トークン化）、決済履歴	購入時
行動データ	アクセスログ、閲覧履歴、購入履歴、検索履歴	サイト利用時
	問い合わせ内容、対応履歴	

区分	具体例	取得経路
問い合わせ情報		カスタマーサポート

2.2 要配慮個人情報

当社のECサイトでは、原則として要配慮個人情報（人種、信条、病歴等）は取得しない。美容・健康カテゴリーの商品購入履歴が間接的に健康情報を示唆する可能性があるため、これらのデータの取り扱いには特に注意する。

第3章 個人情報の取得

3.1 取得時の原則

1. **利用目的の明示**: 個人情報の取得時に利用目的を明確に通知する
2. **必要最小限の取得**: 業務に必要な範囲の情報のみ取得する
3. **適法な手段**: 不正な手段による取得を行わない
4. **本人同意**: 利用目的の範囲を超えて利用する場合は、本人の同意を得る

3.2 プライバシーポリシー

- ・ECサイト上にプライバシーポリシーを掲載し、会員登録時に同意を取得する
- ・プライバシーポリシーの変更時は、変更内容をメールで通知し、30日間の異議申立期間を設ける

第4章 個人情報の管理

4.1 アクセス制御

データ区分	アクセス可能な部門	承認者
会員情報（氏名・連絡先）	カスタマーサポート部、マーケティング部	各部門長
決済情報	経理部のみ	経理部長 + DPO
アクセスログ	インフラ管理部、セキュリティ管理部	セキュリティマネージャー

データ区分	アクセス可能な部門	承認者
購入履歴（集計データ）	EC事業部全体	なし（集計データは制限なし）
購入履歴（個人データ）	カスタマーサポート部	CSマネージャー

4.2 データ保持期間

データ種別	保持期間	根拠
会員情報	退会後5年	商法（取引記録の保存義務）
注文・決済データ	取引日から7年	法人税法（帳簿保存義務）
アクセスログ	1年	社内規程
問い合わせ履歴	対応完了後3年	社内規程
Cookie・行動データ	取得後180日	プライバシーポリシー

4.3 データ保持期間経過後の処理

- ・保持期間が経過したデータは、四半期ごとのデータパージジョブで自動削除
- ・削除ログを1年間保持し、監査対応可能な状態を維持

第5章 個人情報の利用

5.1 利用目的

利用目的	使用するデータ
注文処理・配送	氏名、住所、電話番号
カスタマーサポート	会員情報、注文履歴、問い合わせ履歴
マーケティング（メール配信）	メールアドレス、購入履歴（オプトイン者のみ）
サービス改善	アクセスログ、行動データ（匿名化後）
不正検知	アクセスログ、購入パターン

5.2 第三者提供

- ・ 配送業者への配送情報の提供: 必要最小限の情報（氏名、住所、電話番号）のみ
- ・ 決済代行会社: Stripeへの決済データの提供（PCI DSS準拠）
- ・ 上記以外の第三者への提供は、本人の事前同意なく行わない

第6章 セキュリティ対策

6.1 技術的対策

対策	内容
暗号化	通信: TLS 1.3、保存: AES-256
パスワード	bcryptによるハッシュ化
クレジットカード	トークン化（Stripe Vault）
アクセス制御	RBAC（Role-Based Access Control）
監査ログ	全アクセスを記録、1年間保持
脆弱性診断	年2回の外部ペネトレーションテスト

6.2 組織的対策

- ・ DPO（データ保護責任者）の任命: 法務部 高橋次郎
- ・ 情報セキュリティ委員会: 四半期ごとに開催
- ・ 従業員研修: 年1回の個人情報保護研修（全従業員必須）
- ・ 委託先管理: 個人情報取扱委託先との契約書に安全管理措置を明記

第7章 本人からの請求対応

7.1 対応すべき請求

請求種別	対応期限	手数料
開示請求	受付後2週間以内	無料
訂正・追加・削除請求	受付後2週間以内	無料

請求種別	対応期限	手数料
利用停止・消去請求	受付後1ヶ月以内	無料
第三者提供停止請求	受付後2週間以内	無料

7.2 本人確認

- ・マイページからの請求: ログイン状態をもって本人確認とする
- ・メール・電話での請求: 登録メールアドレスからの送信 + 会員番号の一致

第8章 インシデント対応

8.1 個人情報漏洩時の対応

1. **検知・初動** (即時): 漏洩範囲の特定、被害拡大防止
2. **報告** (24時間以内): DPO→経営層→個人情報保護委員会（必要な場合）
3. **本人通知** (速やかに): 影響を受けた顧客への通知
4. **再発防止** (1ヶ月以内): RCA実施、対策の策定と実装

8.2 報告基準

- ・漏洩件数1件以上: DPOに報告
- ・漏洩件数100件以上: 経営層に報告 + 個人情報保護委員会への報告を検討
- ・要配慮個人情報の漏洩: 件数に関係なく個人情報保護委員会に報告

付録 用語集

用語	説明
PII	Personally Identifiable Information（個人を特定できる情報）
DPO	Data Protection Officer（データ保護責任者）
RBAC	Role-Based Access Control（ロールベースアクセス制御）
PCI DSS	Payment Card Industry Data Security Standard（クレジットカード業界のセキュリティ基準）
トークン化	クレジットカード番号等を意味のないトークンに置換して保存する方法